

Estrutura do Relatório de Conformidade – LGPD e Segurança de Dados

Projeto: Civitas / Versão 1.0

Data: 11 de junho de 2026

Equipe: Isaac Lovisi, Lucas Alberto, Pedro Calderón, Pedro Quartin e Artur Jardim

1. Descrição do Cenário

O sistema analisado consiste em um pipeline automatizado de extração, transformação e carga (ETL) desenvolvido em Python, com o intuito de organizar e melhorar a exibição de dados do Congresso Nacional brasileiro. O fluxo operacional realiza o consumo de dados estruturados diretamente da API de Dados Abertos da Câmara dos Deputados.

Tipo de Dados Coletados

O pipeline coleta e armazena informações cadastrais dos parlamentares, as quais incluem:

- **Identificadores únicos:** ID interno da API.
- **Dados civis e demográficos:** Nome civil, sexo, data de nascimento e nível de escolaridade.
- **Dados políticos e institucionais:** Nome parlamentar, sigla do partido e unidade federativa (UF).
- **Informações de contato e comunicação:** E-mail institucional, telefone do gabinete, endereço de website e links de redes sociais.

Finalidade Declarada

A extração e a persistência desses dados possuem como objetivo a consolidação de uma base de dados relacional local. Esse armazenamento estruturado visa subsidiar ferramentas internas de análise, auditoria de mandatos e cruzamento de informações públicas. Nesse contexto, os dados são tratados sob o amparo legal do acesso à informação e do interesse público.

2. Riscos Identificados

A identificação de riscos consiste na análise sistemática de potenciais ameaças que podem afetar a segurança, a conformidade legal e a integridade dos dados e processos. Esse mapeamento permite reconhecer vulnerabilidades, avaliar impactos e priorizar ações preventivas, servindo como base para a implementação de controles adequados e para a mitigação de incidentes que possam comprometer o funcionamento seguro e eficiente do sistema.

Apesar de a fonte primária ser pública, o armazenamento local e a manipulação desses registros introduzem vulnerabilidades que exigem atenção técnica.

Possíveis Violações da LGPD

Os dados de contato (e-mail e telefone de gabinete) coletados pelo sistema possuem destinação estritamente institucional. Contudo, o armazenamento centralizado sem travas de exportação cria o risco de desvio de finalidade. Desse modo, o uso dessa base para campanhas de marketing não autorizadas ou *spam* violaria o princípio da finalidade previsto na legislação.

Riscos de Reidentificação ou Exposição de Dados

Os dados coletados são salvos em sua totalidade em formato de texto limpo (*plaintext*). Visto que o sistema não aplica nenhuma camada de criptografia na base local `deputados.db`, qualquer vazamento físico ou lógico do arquivo do banco de dados exporá integralmente o histórico de dados dos titulares.

Riscos de Propaganda Eleitoral Não Autorizada

O envio ou veiculação de material de propaganda eleitoral sem autorização constitui infração legal e sujeita os responsáveis a sanções civis, administrativas e criminais. Ainda que os dados utilizados para essa finalidade sejam obtidos de fontes públicas ou institucionais, a utilização indevida para promoção de candidatos ou partidos eleitorais caracteriza violação do princípio da finalidade e do disposto na legislação eleitoral. Além disso, campanhas não autorizadas podem gerar exposição indevida de dados pessoais, reputação negativa da instituição ou pessoa envolvida, e potenciais responsabilidades por danos decorrentes do uso irregular das informações coletadas.

Falhas de Segurança e Ausência de Controles

- **Ausência de Autenticação:** O banco de dados SQLite opera localmente e não exige credenciais de acesso (usuário e senha) para leitura ou escrita.
- **Logs com Dados Expostos:** Embora o sistema possua uma estrutura de logs segregada, o arquivo `validation_errors.log` pode registrar informações sem mascaramento prévio em caso de falhas críticas.

3. Medidas de Segurança Aplicadas

Para reduzir os riscos associados ao tratamento das informações coletadas, foram implementadas medidas de segurança voltadas à proteção da **confidencialidade, integridade e disponibilidade dos dados**. Essas medidas incluem validação de dados, segregação de logs operacionais e adoção de boas práticas de desenvolvimento, buscando minimizar a ocorrência de acessos não autorizados, alterações indevidas e vazamentos de informações. O código atual apresenta controles operacionais e de engenharia focados na estabilidade do pipeline e no monitoramento de falhas.

Técnicas de Anonimização ou Pseudonimização Utilizadas

Nenhuma técnica de anonimização ou pseudonimização foi implementada na arquitetura atual. A justificativa técnica baseia-se na necessidade de identificar nominalmente os agentes políticos para que as análises pretendidas façam sentido prático.

Políticas de Controle de Acesso

O controle de acesso não está implementado na camada de aplicação **ainda**. Nesse contexto, a segurança dos dados depende exclusivamente das políticas de permissão do sistema operacional onde o arquivo `deputados.db` está localizado.

Procedimentos de Retenção e Descarte de Dados

O processo de carga utiliza a cláusula `INSERT OR REPLACE` no banco de dados. Essa abordagem garante a idempotência do pipeline, atualizando os registros existentes e evitando a duplicação de dados.

Monitoramento e Auditoria de Acessos

O sistema dispõe de uma arquitetura de monitoramento baseada na biblioteca `logging` do Python, com quatro saídas distintas:

- `etl.log`: Registra o ciclo de vida da execução e o volume de registros processados.
- `api_errors.log`: Captura falhas de comunicação HTTP e respostas de esgotamento de limite de requisições (*rate limit*).
- `validation_errors.log`: Armazena os desvios de integridade de dados encontrados durante a validação.
- `skipped_records.log`: Monitora falhas ocorridas estritamente na etapa de inserção no banco de dados.

4. Adequação à LGPD

A **Lei Geral de Proteção de Dados Pessoais** (Lei nº 13.709/2018), conhecida como **LGPD**, é a legislação brasileira que estabelece regras para a coleta, armazenamento, tratamento e compartilhamento de dados pessoais. Seu objetivo é garantir a proteção da privacidade e dos direitos fundamentais dos titulares dos dados, definindo princípios, direitos e obrigações que devem ser observados por organizações públicas e privadas durante todo o ciclo de vida das informações pessoais. Abaixo é apresentada a avaliação de conformidade do projeto frente aos princípios fundamentais da lei.

Princípio / Requisito	Status de Adequação	Evidência Técnica / Observação
Finalidade	Adequado	Os dados são coletados exclusivamente para a análise pública pretendida no escopo do projeto.

Necessidade	Parcialmente Adequado	O script realiza a coleta detalhada de campos como sexo e data_nascimento . Ademais, a real necessidade de processar esses dados específicos deve ser reavaliada frente ao objetivo da aplicação.
Transparência	Adequado	Os dados são originados de uma fonte pública oficial regulada por lei de transparência ativa.
Segurança	Insuficiente	O sistema protege a integridade do fluxo contra falhas de rede (através de <i>timeouts</i> e retentativas), contudo falha em proteger os dados em repouso (<i>data at rest</i>).
Direitos do Titular	Não Implementado	Não existem rotinas ou interfaces construídas no código para atender requisições de exclusão ou portabilidade diretamente pelo titular.

5. Conclusão e Recomendações

O projeto Civitas apresenta uma arquitetura funcional madura sob a ótica da engenharia de dados, demonstrando excelente resiliência contra instabilidades de rede e tratamento de erros de API. Contudo, sob o prisma da segurança da informação e da conformidade com a LGPD, o cenário exige melhorias estruturais imediatas, visto que a base de dados encontra-se exposta e desprotegida localmente.

Pontos Fortes da Conformidade

- **Idempotência Garantida:** A atualização de registros existentes impede o crescimento desordenado e a redundância da base de dados.
- **Tratamento de Rate Limit:** A implementação do recuo exponencial (*exponential backoff*) em respostas HTTP 429 evita o bloqueio da aplicação e demonstra boas práticas de consumo de APIs públicas.
- **Rastreabilidade do Processo:** O sistema de logs ramificado permite identificar com precisão em qual etapa do fluxo ocorreu uma anomalia.

Melhorias Sugeridas para Maior Segurança

1. **Criptografia da Base de Dados:** Substituir o conector padrão do SQLite pelo uso do `SQLCipher`, permitindo que o arquivo `deputados.db` seja totalmente criptografado em repouso por meio de uma chave de segurança robusta.
2. **Segregação e Minimização de Campos:** Avaliar a real necessidade analítica de armazenar a data de nascimento e o sexo dos parlamentares. Caso esses campos não sejam utilizados nas regras de negócio, eles devem ser removidos do dicionário de transformação.
3. **Mascaramento de Dados nos Logs:** Revisar o validador para assegurar que, em caso de erro de validação, os dados pessoais dos titulares não sejam gravados de forma explícita nos arquivos de texto de log.